COMPTE RENDU : TP 1.4 — Scan et analyse de sécurité d'un système Windows 10

1. Introduction

→ **Threat Intelligence :** Capacité d'analyser une menace à partir de données publiques (OSINT) pour anticiper les attaques.

→ **Rôle :** Permet au SOC de comprendre les tactiques des attaquants et de renforcer les défenses avant une intrusion.

2. Analyse des services

```
┌──(root㉿kali)-[/home/taneyo]
└─# nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 03:01 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:0C:29:8B:4E:46 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 10.13 seconds
```

Figure 1 : Identification des ports ouverts (ex : 135, 139, 445, 3389).

La commande utilisée est **nmap -sS 192.168.56.20**. C'est un **SYN Scan** (semi-ouvert). Il est rapide et discret car il ne termine pas la connexion TCP. Il confirme simplement quels ports sont ouverts.

```
┌──(root㉿kali)-[/home/taneyo]
└─# nmap -sV 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 02:58 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0014s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds  Microsoft Windows 7 - 10 microsoft-ds (workgroup: W
ORKGROUP)
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:0C:29:8B:4E:46 (VMware)
Service Info: Host: DESKTOP-QV1CQ1A; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.49 seconds
```

Figure 2 : identification précise des services + versions

La commande est nmap -sV 192.168.56.20. Ici, Nmap interroge les ports ouverts pour déterminer exactement **quel service** et **quelle version** s'y exécutent. On voit ainsi apparaître les précisions sur « Microsoft Windows RPC » par exemple.

```
┌──(root㉿kali)-[/home/taneyo]
└─# nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 03:13 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00070s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:8B:4E:46 (VMware)

Host script results:
| smb-os-discovery:
|   OS: Windows 10 Pro 10586 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-QV1CQ1A
|   NetBIOS computer name: DESKTOP-QV1CQ1A\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-17T02:13:26+02:00

Nmap done: 1 IP address (1 host up) scanned in 5.11 seconds
```

Figure 3 : Extraction du nom de la machine et de la version de Windows.

Le port 445 (SMB) est critique car il est souvent ciblé par des ransomwares comme WannaCry.

3. Détection de vulnérabilités SMB

- **Objectif de la commande :** Utiliser les scripts NSE (Nmap Scripting Engine) pour tester spécifiquement les vulnérabilités connues du protocole SMB sur la cible Windows.
- **Analyse des résultats :**
  - **SMBv2 :** Le script confirme que la cible supporte le protocole SMBv2, ce qui est standard mais nécessite une surveillance des vulnérabilités de type **"Man-in-the-Middle".**
  - **Vulnérabilités critiques :** Le scan n'a pas détecté de vulnérabilité immédiate de type **ms17-010 (EternalBlue) ou smb-vuln-ms10-061** sur cette machine au moment du test.

Cette capture démontre une phase de reconnaissance approfondie. Bien qu'aucune faille critique immédiate ne soit listée en rouge, l'exposition du **port 445** avec **SMBv2** actif reste un vecteur d'attaque potentiel qu'un analyste SOC doit surveiller de près pour éviter toute propagation de malware.

```
┌──(root㉿kali)-[/home/taneyo]
└─# nmap --script smb-vuln* -p 445 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 03:04 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00068s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:8B:4E:46 (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-fo
r-wannacrypt-attacks/
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 10.21 seconds
```

Figure 4 : Affiche si la machine est vulnérable à EternalBlue.

Les services comme SMB et RDP (3389) présentent les risques les plus élevés s'ils sont mal configurés ou non patchés.

```
┌──(root㉿kali)-[/home/taneyo]
└─# nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-17 02:47 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00056s latency).

PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
| rdp-enum-encryption:
|   Security layer
|     CredSSP (NLA): SUCCESS
|     CredSSP with Early User Auth: SUCCESS
|_    RDSTLS: SUCCESS
MAC Address: 00:0C:29:8B:4E:46 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.47 seconds
```

Figure 5 : analyse des protocole RDP

Objectif de la commande : Analyser le service de Bureau à distance (RDP) pour identifier les méthodes de chiffrement supportées et les risques de sécurité associés.

Analyse des résultats :

- **Port 3389 :** Le service RDP est confirmé comme **ouvert** (open) sur la cible.
- **Chiffrement détecté :** Le scan identifie que la cible accepte le chiffrement RDP standard ainsi que **SSL (TLS)**.
- **Alerte de sécurité :** Le script indique que **le chiffrement NLA (Network Level Authentication)** n'est pas nécessairement requis de manière stricte, ce qui peut exposer la machine à des attaques par déni de service ou à du brute force avant même l'authentification

L'analyse du service RDP révèle que la machine accepte plusieurs méthodes de chiffrement. La présence du protocole SSL est positive, mais l'ouverture du port 3389 sans restriction d'IP constitue une surface d'attaque majeure pour une entreprise.

4. Conclusion

Nous pouvons dire qu'après toutes choses que, avoir l'information est une arme mais savoir identifier précisément un service permet de choisir l'exploit adéquat. Pour cela il faut alors désactiver SMBv1, limiter l'accès RDP et activer le pare-feu.